BioSpecInfo

Security, Privacy & Compliance — BioSpecInfo

Samuele Pio Provenzano

Versione **bsi-v242** · commit `d229adf`

Generato il 2026-11-05

Documento generato automaticamente dal sorgente Markdown versionato nel repository. La versione e il commit stampati in ogni piè di pagina identificano esattamente lo stato del software descritto.

Security, Privacy & Compliance — BioSpecInfo

Field	Value
Software	BioSpecInfo
Author	Samuele Pio Provenzano
Model	Client-side / Local-First PWA

1. Privacy & data protection (GDPR)

1.1 Local-First by design

- **No account, no login, no advertising tracking.**
- All user data (drawn molecules, preferences, quiz history, study progress) is

stored **exclusively locally** on the device (`localStorage` / IndexedDB / `sql.js`), with no transmission to author-controlled servers.

- **There is no application backend** collecting or processing personal data.

1.2 Data handling and GDPR alignment

- **Data minimisation:** the app requires no personal data to function.
- **No transfer to the author's third parties:** data never leaves the device for

infrastructure controlled by the author.

- **Optional, transparent external calls:** only upon a user action (searching a

molecule, opening a 3D model) does the app query public third-party APIs (PubChem, NASA/ESA, spectral databases). Such requests contain **only the chemical identifier** (e.g. SMILES/name) and **no personal data**. Use of these services is subject to their respective privacy policies.

- **Spectra's quality voice (since v239, `bsi-spectra-voce.js`):** if the user

has saved an OpenAI key in the app, the **text Spectra speaks** (up to 3,800 characters at a time: console answers, guided-lesson steps, Spectra Studio texts) is sent directly from the browser to `api.openai.com/v1/audio/speech` (`gpt-4o-mini-tts` , voice «onyx»; `tts-1` as fallback), with the user's key. This happens **even when the chat uses another provider**, and the request does not go through the proxy. The text may contain what the user asked and what Spectra remembers about the user. The audio received stays only in memory for the session. Without an OpenAI key this flow does not exist: the browser's speech synthesis is used. To avoid it, turn the voice off (🔇) in the console, in the guided lesson and in Spectra Studio, where the choice is remembered (`bsi-spectra-studio-voce`); or do not save an OpenAI key.

- **«🧠 Spiega» and the screen (`bsi-spectra-spiega.js`, v240):** with the

«📺 Includi lo schermo» checkbox checked (it is checked by default when a section is open behind the window), the configured AI provider receives, with its key and together with the question, **the screen text** (section, tab, control values, visible tables and text) and **an image of the visible graphs and 3D scenes**, like a chat attachment; the image is sent in the first turn only. With the checkbox unchecked only the question is sent. **An unchecked box is respected**: even when Spectra opens a section named in the question («spiegami le titolazioni») or chosen from the «🗂️ Tutte le sezioni nell'ologramma» catalogue, the section opens behind the window and is shown in the hologram, but the box stays unchecked and the model receives only the question, with no screen text or image. Only the quick prompts about the screen («📈 Spiegami questo grafico»…) check it again, since they are an explicit choice. Without a key nothing leaves the device. The conversation is kept in memory for the session and is not saved.

- **Spectra's body (since v241):** the body is embedded in the app

(`models/spectra-corpo.bsi`, downloaded from the app's own site and kept in the service worker's cache); the user no longer loads any file and nothing is written to IndexedDB any more. On start an old body stored by a previous version (database `bsi-spectra-modelli`), if any, is deleted; «Clear data → Progress in the rest of the app» still deletes that database.

- **Local right to erasure:** the user can delete data by clearing the site

storage in the browser.

> **Note.** This alignment describes the local-first design properties that favour GDPR compliance. It does not constitute a legal certification; for regulated contexts a dedicated DPIA assessment is recommended.

---

2. Application security (OWASP)

2.1 Attack surface

Being a **static application with no backend**, entire classes of server-side vulnerabilities are absent by construction (SQL injection on a server DB, server-side RCE, server authentication/session, IDOR on proprietary APIs).

2.2 Input sanitisation

- Parsing of **SMILES / SMARTS** strings and molecular files is delegated to

RDKit MinimalLib (WASM), which validates the structures and rejects malformed input by returning invalid molecules rather than executing them.

- Strings coming from user input or external APIs, when inserted into the DOM,

are treated as untrusted. Their textual value (names, notations) is shown as text content/`textContent` or with escaping of the `& < >` characters.

2.3 Runtime robustness

- `localStorage` **guard:** every storage access is protected by `try/catch` with

an in-memory fallback, so that incognito mode or blocked storage cannot halt execution (a historical regression that has been fixed).

- **Controlled degradation:** panels never silently stay empty; errors show a

message and, where applicable, a "Retry" button.

- **Sub-app isolation** in `iframe`s.

2.4 Content Security Policy (deployment recommendation)

Since the app can be published on static hosting, it is recommended to serve it with security headers at the hosting/CDN level:

- Restrictive `Content-Security-Policy` (self script/style + WASM),

`frame-ancestors`, `X-Content-Type-Options: nosniff`, `Referrer-Policy: no-referrer`.

- `Cross-Origin-Opener-Policy` / `Cross-Origin-Embedder-Policy` if

`SharedArrayBuffer` and parallel Web Workers are enabled in the future (HPC roadmap).

2.5 Page-side checks: deterrents, not locks

On static hosting every check made in the page can be bypassed by whoever holds the device or reads the source. Two features declare it:

- **File Manager** (`file_manager.html`): the password is compared as a SHA-256

fingerprint; it is a deterrent against passers-by, not protection for confidential documents (`08-Traceability-Matrix.md`, SEC-03).

- **Spectra's creator recognition** (`bsi-spectra-creatore.js`, since version

`bsi-v238`): on «I am your creator» Spectra asks for the same secret phrase as the File Manager, typed into a password field and compared as a SHA-256 fingerprint. The phrase does not appear in the code, is not stored and enters neither the dialogue, nor memory, nor voice, nor the requests to the model; after three wrong attempts there is a one-minute wait. Only the mark `bsi-spectra-creatore-v1` stays in `localStorage`, erasable from «Clear data → Persistent memory». **It is not an access control**: the fingerprint is in the code, the mark can be written by hand by whoever holds the device, and an unsalted fingerprint of a weak phrase can be searched by trial outside the app. It protects no data: it tells Spectra whom it is talking to (`08-Traceability-Matrix.md`, SEC-08; `09-Release-Conformance-Statement.md`, D-13).

---

3. Integrity and reproducibility (GAMP 5 alignment)

For use in pharmaceutical/regulated contexts, the architecture is **compatible** with GAMP 5 principles:

- **Determinism:** the cheminformatics computations (RDKit) are deterministic and

reproducible for the same input.

- **Version traceability:** code versioning on Git, versioned Service Worker cache, changelog.
- **Method transparency:** the heuristic predictors are documented with their sources and limitations (see the *Validation Report*).

> Again: this is **alignment with the principles**, not a formal qualification (IQ/OQ/PQ), which would require a dedicated validation process at the using organisation.

---

4. Summary

Aspect	Status
Personal data transmitted to author's servers	**None**
Text spoken by Spectra sent to OpenAI for the voice	**Only with a saved OpenAI key** (§1.2)
Backend / server database	**Absent**
Molecular input validation	RDKit WASM
DOM output escaping	Yes (untrusted content)
Storage guard / error degradation	Yes
CSP / security headers	Recommended at hosting level
Offline operation	Yes (Service Worker)